Security Test Case

Đạt	7
Không Đạt	3
Không chạy	0
Chưa test	0
Tổng ca kiểm thử	10

Nhóm chức năng	Mã ca kiểm thử	Mô tả ca kiểm thử	Dữ liệu kiểm thử	Các bước thực hiện	Kết quả mong đợi	Kết quả thực tế	Nguyên nhân	Kết luận
HTTPS và Cookie	SEC01	Kiểm tra giao thức truyền dữ liệu và cơ chế lưu trữ thông tin xác thực	Website và Backend đang hoạt động; có tài khoản người dùng hợp lệ	1. Truy cập StayTour, kiểm tra giao thức HTTP/HTTPS 2. Mở F12 => Network, kiểm tra Request URL của API 3. Đăng nhập tài khoản khách hàng 4. Kiểm tra JWT trong Application => Local Storage 5. Kiểm tra Cookies và các thuộc tính HttpOnly, Secure, SameSite 6. Kiểm tra JWT được gửi qua Authorization Bearer trong Network 7. Đăng xuất, kiểm tra JWT có bị xóa khỏi Local Storage không	Website triển khai thực tế sử dụng HTTPS. Nếu sử dụng cookie phiên, cookie được cấu hình các thuộc tính bảo mật phù hợp; thông tin xác thực không bị lộ qua kết nối không an toàn	Website và API sử dụng HTTP localhost; JWT lưu trong Local Storage và gửi qua Authorization Bearer	Chưa triển khai HTTPS để xác minh mã hóa đường truyền; JWT lưu trong Local Storage nên không áp dụng được các thuộc tính bảo mật của cookie phiên	Không Đạt
Password Hashing	SEC02	Kiểm tra mật khẩu không được lưu dưới dạng văn bản rõ	Chức năng đăng ký và quyền xem mã nguồn hoặc database	1. Đăng ký tài khoản mới với mật khẩu hợp lệ 2. Mở phpMyAdmin, chọn database tmdt và tìm tài khoản vừa đăng ký 3. Kiểm tra giá trị trường password trong bảng User 4. Mở mã nguồn Backend, kiểm tra hàm bcrypt.hash() khi đăng ký và bcrypt.compare() khi đăng nhập 5. Đăng nhập bằng mật khẩu đúng và thử lại bằng mật khẩu sai	Mật khẩu được băm bằng bcrypt trước khi lưu vào database, không lưu dạng văn bản rõ. Mật khẩu đúng đăng nhập thành công, mật khẩu sai bị từ chối	Mật khẩu được lưu dưới dạng chuỗi băm bcrypt, không trùng với mật khẩu gốc. Hệ thống sử dụng bcrypt.hash() và bcrypt.compare() để xử lý mật khẩu		Đạt
Kiểm tra SQL Injection và dữ liệu đầu vào	SEC03	Kiểm tra phòng chống SQL Injection và xác thực dữ liệu đầu vào	OR '1'='1	1. Nhập chuỗi SQL Injection vào ô tìm kiếm và thực hiện tìm kiếm. 2. Kiểm tra kết quả hiển thị trên website. 3. Mở DevTools => Network, kiểm tra phản hồi API. 4. Nhập dữ liệu không hợp lệ vào biểu mẫu đăng ký. 5. Kiểm tra thông báo lỗi và phản hồi Backend. 6. Đối chiếu mã nguồn sử dụng Prisma ORM và kiểm tra dữ liệu đầu vào	Chuỗi SQL Injection không làm thay đổi truy vấn hoặc tiết lộ dữ liệu; dữ liệu không hợp lệ bị từ chối; Backend sử dụng truy vấn an toàn	Chuỗi SQL Injection được xử lý như dữ liệu tìm kiếm thông thường, trả về 0 kết quả; không xuất hiện lỗi SQL hoặc dữ liệu bất thường		Đạt
Kiểm tra XSS, CSP	SEC04	Kiểm tra ngăn chặn thực thi mã XSS và cấu hình CSP	<img src=x onerror=alert('XSS_TEST')>	1. Nhập chuỗi XSS vào nội dung đánh giá homestay. 2. Gửi đánh giá và đăng nhập Admin để duyệt. 3. Kiểm tra nội dung tại trang quản trị. 4. Duyệt đánh giá, mở trang chi tiết homestay. 5. Kiểm tra mã JavaScript có được thực thi không. 6. Mở Network => Response Headers, kiểm tra CSP.	Chuỗi XSS không được thực thi tại cả hai trang; CSP được cấu hình phù hợp	Chuỗi XSS hiển thị dưới dạng văn bản tại trang quản trị và trang khách hàng, không thực thi JavaScript. Không tìm thấy header Content-Security-Policy trong phản hồi Document và API	Hệ thống xử lý an toàn chuỗi XSS đã thử nhưng chưa cấu hình CSP để bổ sung lớp bảo vệ chống thực thi nội dung không tin cậy	Không Đạt
Kiểm tra CSRF	SEC05	Kiểm tra ngăn chặn yêu cầu thay đổi dữ liệu trái phép CSRF	Yêu cầu API thay đổi dữ liệu không có thông tin xác thực hợp lệ	1. Đăng nhập, mở hồ sơ và ghi nhận họ tên 2. Cập nhật họ tên, kiểm tra API PUT /api/auth/profile trong Network 3. Gửi lại yêu cầu sau khi xóa Authorization 4. Từ trang localhost:5500/CSRF.html, gửi yêu cầu PUT không kèm JWT 5. Kiểm tra mã phản hồi và tải lại hồ sơ để đối chiếu	Yêu cầu trái phép bị từ chối, dữ liệu hồ sơ không thay đổi	Yêu cầu hợp lệ trả về 200; yêu cầu thiếu JWT và từ trang khác nguồn trả về 401. Họ tên không thay đổi	Backend từ chối yêu cầu không có JWT hợp lệ	Đạt
Kiểm tra phân quyền và quyền sở hữu dữ liệu	SEC06	Kiểm tra người dùng không thể truy cập dữ liệu hoặc chức năng ngoài quyền hạn		1. Đăng nhập tài khoản khách hàng, thử truy cập trang quản trị và kiểm tra quyền truy cập 2. Đăng nhập tài khoản A, mở Đơn của tôi và lấy mã đơn 3. Đăng xuất A, đăng nhập tài khoản B và lấy JWT của B 4. Dùng PowerShell gửi yêu cầu GET /api/orders/my/ma-don với JWT của B 5. Kiểm tra mã phản hồi và dữ liệu trả về	Khách hàng không được truy cập chức năng quản trị; tài khoản B không xem được đơn của A	Tài khoản khách hàng không truy cập được chức năng quản trị. Khi dùng JWT của tài khoản B để truy cập đơn của tài khoản A, API trả về 404, không hiển thị dữ liệu đơn	Backend kiểm tra quyền truy cập theo vai trò và quyền sở hữu đơn đặt chỗ	Đạt

Security Test Case

Đạt	7
Không Đạt	3
Không chạy	0
Chưa test	0
Tổng ca kiểm thử	10

Nhóm chức năng	Mã ca kiểm thử	Mô tả ca kiểm thử	Dữ liệu kiểm thử	Các bước thực hiện	Kết quả mong đợi	Kết quả thực tế	Nguyên nhân	Kết luận
Kiểm tra tệp tải lên	SEC07	Kiểm tra hệ thống có từ chối tệp giả ảnh khi tải lên	Ảnh hợp lệ .jpg; tệp fake.jpg chứa văn bản, khai báo MIME image/jpeg	1. Đăng nhập Admin và tải ảnh JPG hợp lệ 2. Kiểm tra phản hồi API upload 3. Tạo tệp văn bản fake.jpg 4. Dùng PowerShell gửi tệp giả ảnh đến API với MIME image/jpeg 5. Kiểm tra mã HTTP và dữ liệu trả về.	Ảnh JPG hợp lệ được chấp nhận; tệp giả ảnh bị từ chối và không được lưu	Ảnh JPG hợp lệ trả về 201 Created. Tệp giả JPG cũng trả về 201 Created, API cung cấp tên tệp và URL lưu trữ	Backend chưa xác minh nội dung thực của tệp, chỉ kiểm tra MIME khai báo	Không Đạt
Kiểm tra giới hạn đăng nhập và ghi vết	SEC08	Kiểm tra cơ chế khóa tạm thời khi đăng nhập sai nhiều lần và ghi nhận sự kiện bảo mật	Email tài khoản thử nghiệm; mật khẩu sai SaiMatKhau@123; mật khẩu đúng	1. Đăng nhập sai nhiều lần 2. Kiểm tra thông báo khóa tài khoản 3. Mở phpMyAdmin => tmdt => loginattempt 4. Đối chiếu email, trạng thái và thời gian đăng nhập	Hệ thống khóa tạm thời khi đăng nhập sai nhiều lần và lưu lịch sử đăng nhập	API trả về LOCKED, thông báo khóa 15 phút. Bảng loginattempt ghi nhận các lần đăng nhập thất bại và thành công, kèm IP và thời gian	Hệ thống có cơ chế giới hạn đăng nhập và lưu bản ghi đăng nhập trong database	Đạt
Kiểm tra an toàn giao dịch thanh toán	SEC09	Xác minh hệ thống sử dụng VNPAY Sandbox và không lưu dữ liệu thẻ thanh toán nhạy cảm	Đơn đặt chỗ hợp lệ, thông tin thanh toán VNPAY Sandbox	1. Tạo đơn đặt chỗ và chọn thanh toán VNPAY 2. Kiểm tra chuyển hướng đến trang VNPAY Sandbox 3. Thực hiện giao dịch bằng thông tin thanh toán thử nghiệm 4. Mở phpMyAdmin, kiểm tra các bản ghi trong bảng payment 5. Truy vấn cấu trúc database để tìm các trường liên quan đến số thẻ, CVV, CVC, PIN và OTP 6. Đối chiếu dữ liệu thanh toán với mã nguồn cấu hình	Thanh toán qua VNPAY Sandbox; không lưu số thẻ, CVV, PIN hoặc OTP trong database	Hệ thống sử dụng VNPAY Sandbox; không phát hiện trường lưu dữ liệu thẻ nhạy cảm trong cấu trúc database đã kiểm tra		Đạt
Kiểm tra sao lưu, phục hồi và chính sách dữ liệu	SEC10	Kiểm tra khả năng sao lưu, phục hồi dữ liệu và việc tuân thủ chính sách bảo vệ thông tin cá nhân của khách hàng	Database, tệp sao lưu SQL, database phục hồi thử nghiệm và tài khoản khách hàng	1. Sao lưu database và phục hồi vào database thử nghiệm 2. Đối chiếu dữ liệu trước và sau phục hồi 3. Kiểm tra điều khoản, chính sách quyền riêng tư và thông tin tài khoản	Dữ liệu được phục hồi đầy đủ; thông tin cá nhân được bảo vệ và có chính sách sử dụng rõ ràng	Quá trình sao lưu và phục hồi diễn ra bình thường, dữ liệu được giữ nguyên. Các chức năng liên quan đến thông tin cá nhân hoạt động		Đạt